

Sensibiliser les utilisateurs à la cybersécurité

D'après les ressources de l'ENISA — AR-in-a-Box SME Edition 2024



Plan

Enjeux & menaces cyber

Programmes ANSSI/CNIL/ENISA

Publics à sensibiliser

Psychologie & biais cognitifs

Messages clés par cible

Scénarios d'attaque illustrés

Plan annuel de sensibilisation

Outils & formats pédagogiques

Simulation phishing interne

Protection données & RGPD

KPIs SMART & mesure

Culture de cybersécurité

Comprendre les enjeux de la sensibilisation en cybersécurité

Objectifs

Expliquer le poids du facteur humain dans les cyberattaques

Citer les chiffres-clés des menaces actuelles (ENISA 2024)

Analyser les programmes de sensibilisation existants (ANSSI, CNIL, ENISA)

Identifier les différents publics à sensibiliser en entreprise

Pourquoi la sensibilisation ? Le facteur humain

90%

des incidents de sécurité
commencent par du phishing

80%

des PME : impact négatif
sérieux en cas d'incident

57%

risquent la faillite
après un incident cyber

Source : ENISA — AR-in-a-Box SME Edition 2024

Le vecteur humain est la première cause de compromission

Les attaquants exploitent les comportements, les habitudes et les erreurs des utilisateurs.
Aucune solution technique ne peut compenser un manque de sensibilisation des équipes.

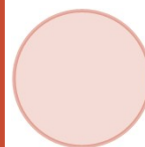
Le paysage des menaces — Panorama 2024



Phishing

90%

des incidents démarrent par un email malveillant.
Vecteur #1 toutes catégories confondues.



Ingénierie sociale

30%

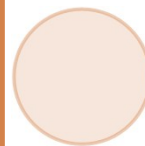
des attaques ciblent le grand public. L'IA amplifie ces techniques en 2024.



Ransomware

34%

des menaces en UE. Durée moyenne d'indisponibilité
: 23 jours après une attaque.



Smishing / Vishing



Attaques via SMS et appels téléphoniques en forte croissance. Difficiles à détecter.

Le phishing — Anatomie d'une attaque

Phishing · Smishing · Vishing : 3 vecteurs, 1 objectif — tromper l'utilisateur

Phishing

Email frauduleux imitant une entité de confiance. Pièce jointe malveillante ou lien vers une fausse page de connexion.

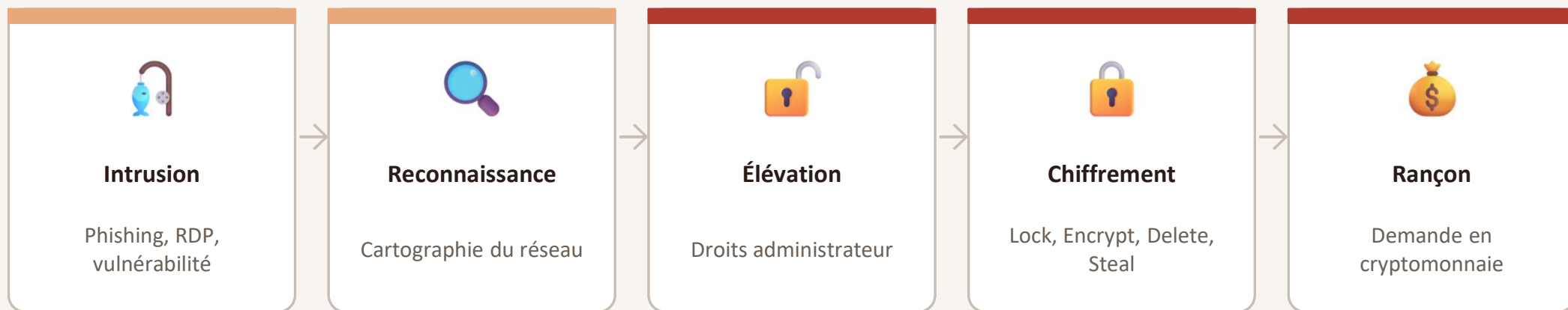
Smishing

SMS malveillant avec lien frauduleux ou demande urgente. Ex : faux avis de livraison, alerte bancaire.

Vishing

Appel téléphonique frauduleux. L'attaquant se fait passer pour un technicien, un banquier ou un supérieur hiérarchique.

Le ransomware — Fonctionnement et impact



23 jours

durée moyenne d'indisponibilité (2021)

€62M

rançons demandées en Europe (2021)

34%

des menaces UE = ransomware

Programmes de référence — ANSSI, CNIL, ENISA

FR ANSSI

- Guide d'hygiène informatique (42 règles)
- Référentiel SecNumCloud
- Campagnes nationales de sensibilisation
- MOOC SecNum Académie (gratuit)



CNIL

- Guides pratiques RGPD
- Outils d'auto-évaluation
- Sensibilisation protection des données
- Formation DPO certifiée

EU ENISA

- AR-in-a-Box (outil complet SME)
- European Cybersecurity Month
- Statistiques menaces annuelles (ENISA Threat Landscape)
- Matériaux pédagogiques libres

ENISA AR-in-a-Box — Un programme clé en main

Boîte à outils complète pour les PME — libre d'accès et adaptable



Template annuel

Plan de sensibilisation structuré (Who/What/How/When/Cost)



KPIs & métriques

Indicateurs SMART pour mesurer l'efficacité des campagnes



Plan de crise cyber

Guide Plan/Execute/Monitor pour communiquer en cas d'incident



Mini-jeu pédagogique

Jeu de rôle 'MiniBiz Hacked' — 5 phases, 60 minutes



Quiz de sensibilisation

Questions sur phishing, ransomware, hygiène numérique



Scénarios réalistes

Cas basés sur phishing, vishing, smishing, ransomware réels

Les publics à sensibiliser — 3 cibles, 3 approches



COMEX / Direction

- Vision stratégique et risques business
- Impact financier et réputationnel
- Responsabilités légales (RGPD, NIS2)
- Tabletop exercise — simulation de crise

 *Langage business, ROI, gouvernance*



Équipes IT / DSI

- Aspects techniques des attaques
- Procédures incident response
- Gestion des accès et IAM
- Tests d'intrusion et outils

 *Langage technique, procédures, métriques*



Utilisateurs métiers

- Reconnaître phishing et scams
- Mots de passe forts et MFA
- Partage sécurisé des données
- Signaler les incidents

 *Langage simple, exemples concrets, quotidien*

EXERCICE

Analyse d'un programme de sensibilisation existant

- 1 Par groupe de 5: choisissez une organisation (PME, hôpital, mairie)
- 2 Identifiez les 3 menaces principales pour cette organisation
- 3 Définissez les publics prioritaires à sensibiliser
- 4 Proposez 2 formats pédagogiques adaptés

Adapter son discours selon la cible

Objectifs

Identifier les biais cognitifs exploités par les attaquants et adapter la formation en conséquence

Gérer l'attention des participants selon la courbe de Ebbinghaus et les techniques de storytelling

Définir des messages clés adaptés à chaque public (COMEX, IT, métiers) en évitant les jargons inadaptés

Sélectionner les canaux de communication appropriés pour maximiser l'impact de la sensibilisation

Utiliser des scénarios d'attaque réels pour illustrer les risques et ancrer les apprentissages

Psychologie de la sensibilisation — Comprendre l'humain

Les attaquants exploitent des mécanismes psychologiques universels



Urgence

Créer une pression temporelle pour court-circuiter la réflexion. Ex : 'Votre compte sera supprimé dans 24h'.



Autorité

Se faire passer pour un supérieur, un banquier ou une autorité. Réduit le questionnement critique.



Confiance

Imiter l'identité visuelle d'une entreprise connue. Exploiter une relation existante.



Peur & menace

Menacer de conséquences négatives. Paralyse le raisonnement et pousse à l'action immédiate.



Récompense

'Vous avez gagné un prix !' La promesse d'un gain incite au clic sans vérification.



Réciprocité

Offrir quelque chose avant de demander. Crée un sentiment d'obligation chez la cible.

Capter l'attention — Storytelling & pédagogie

Une sensibilisation efficace raconte une histoire avant de donner des règles

Principes d'un bon message

- **Concret :** Un cas réel vaut mieux qu'une règle abstraite
- **Émotionnel :** Créer de l'empathie (la victime, c'est 'toi')
- **Simple :** Une idée principale par message
- **Actionnable :** Dire exactement quoi faire
- **Mémorable :** Répétition, format visuel, quiz de rappel

Courbe de l'attention

- | | |
|------------------|--|
| 0-5 min | Accroche forte : chiffre-choc ou histoire réelle |
| 5-20 min | Concepts clés : 3 idées maximum |
| 20-30 min | Activité pratique ou démonstration |
| 30-45 min | Discussion, retours d'expérience |
| 45-50 min | Récapitulatif + call-to-action clair |

Gestion de l'attention et piège des jargons

Deux obstacles majeurs à une sensibilisation efficace — à maîtriser impérativement

Courbe de l'oubli — Ebbinghaus

Après 1 heure

Rétention : ~44 % — perte de 56 %

Après 24 heures

Rétention : ~33 % — perte de 67 %

Après 1 semaine

Rétention : ~25 % — perte de 75 %

Après 1 mois

Rétention : ~21 % sans révision

Solution : répétition espacée + 3 formats différents

Le piège des jargons techniques

X SPF / DKIM / DMARC

→ Votre domaine email est protégé contre l'usurpation

X Payload + macro VBA

→ Un fichier Word piégé qui lance un programme malveillant

X Élévation de privilèges

→ L'attaquant s'est donné les droits d'administrateur

X IOCs + EDR/SIEM

→ Des signaux d'alerte détectés par vos outils de surveillance

X Credential harvesting

→ Vol de mots de passe via une fausse page de connexion

Adapter le message — Même menace, 3 discours différents

Exemple : une campagne de phishing ciblant l'entreprise

COMEX	""Une campagne de phishing peut coûter jusqu'à 3,9M€ en moyenne (IBM). 85% des violations impliquent l'erreur humaine. Votre responsabilité est engagée en vertu de NIS2.""	 Impact business & conformité
IT / DSI	""Nous simulons un email de phishing avec payload Word macro. Voici les IOCs à surveiller dans les logs SIEM et les règles EDR à configurer pour bloquer la chaîne d'infection.""	 Technique & procédure
Utilisateurs	""Si tu reçois un email inattendu qui demande de cliquer sur un lien ou d'ouvrir une pièce jointe, appelle directement la personne avant d'agir. Prends 10 secondes pour vérifier.""	 Comportement & réflexe

Choisir les bons canaux de communication



Email

✓ Tous

⚠ Taux d'ouverture faible



Intranet / Portail

✓ IT, RH

⚠ Visibilité dépend de l'usage



Affichage / Posters

✓ Tous (locaux)

⚠ Impact limité, non interactif



Formation e-learning

✓ Tous

⚠ Nécessite LMS, temps dédié



Jeux / Gamification

✓ Métiers, juniors

⚠ Coût de développement



Simulation phishing

✓ Tous

⚠ Doit s'accompagner de formation



SMS / Push mobile

✓ Métiers mobiles

⚠ Perçu comme intrusif



Chat interne (Teams)

✓ IT, métiers

⚠ Bruit informationnel élevé

 SCÉNARIO RÉEL

MiniBiz — Entreprise hackée

MiniBiz — PME de développement web (< 75 employés) — victime d'une attaque combinée :



Phishing par email



Smishing / Vishing



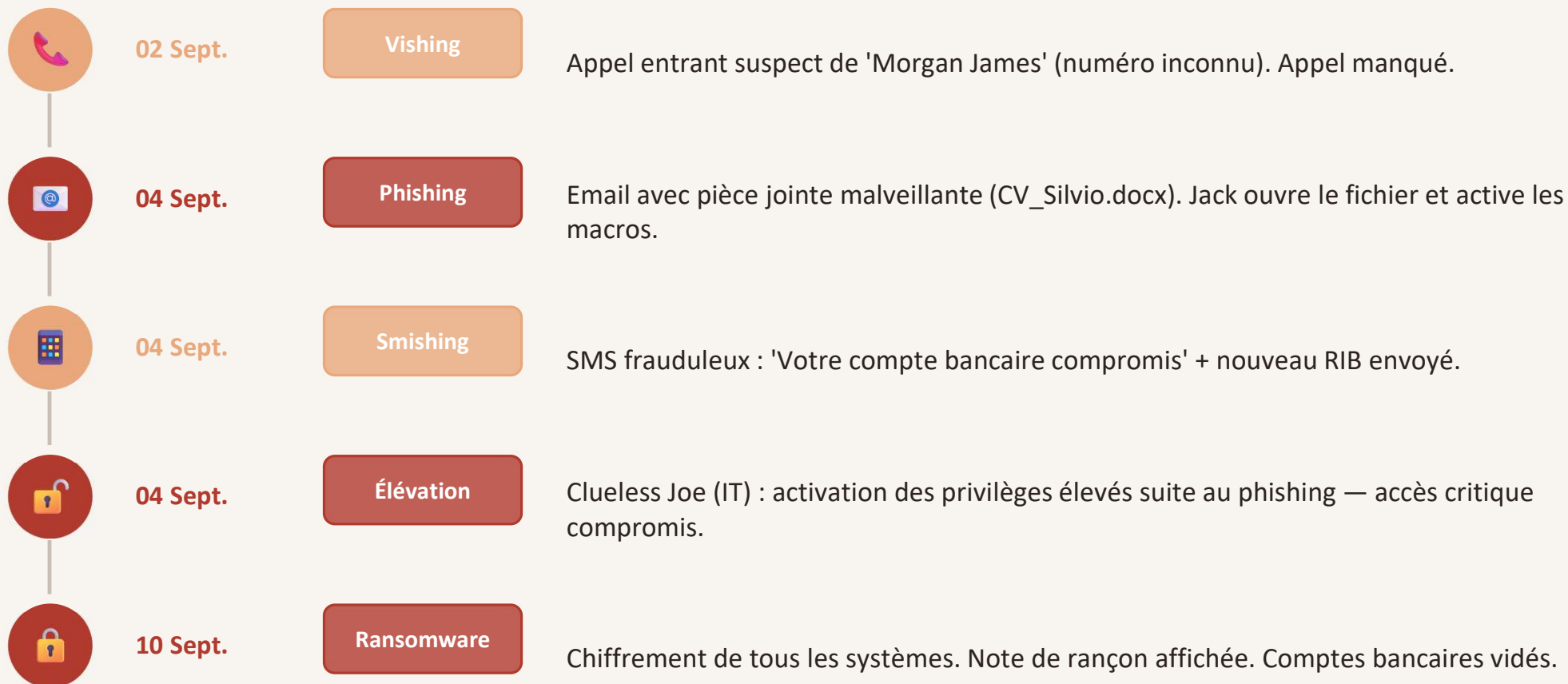
Ransomware



Fraude au virement

Source : ENISA AR-in-a-Box — Mini Game SME Edition 2024

MiniBiz — Chronologie de l'attaque



MiniBiz — Analyse & enseignements

Exercice par groupe

Q1

Quels biais psychologiques ont été exploités dans cette attaque ?

Q2

À quel moment aurait-il été possible de stopper l'attaque ?

Q3

Le processus de paiement était-il suffisamment sécurisé ?

Q4

Quelles mesures de sensibilisation auraient réduit l'impact ?

SYNTHÈSE

Le facteur humain est le maillon faible — 90% des incidents commencent par du phishing

Les programmes ANSSI, CNIL et ENISA fournissent des ressources gratuites et adaptées

COMEX, IT et métiers n'ont pas les mêmes besoins : le discours doit être personnalisé

Les attaquants exploitent l'urgence, l'autorité et la confiance — former aux biais cognitifs

Le storytelling et les scénarios réels améliorent la mémorisation et l'engagement

Concevoir, déployer et évaluer un programme de sensibilisation

Concevoir un programme de sensibilisation innovant

Objectifs

Élaborer un plan de sensibilisation annuel complet avec le template ENISA AR-in-a-Box (8 dimensions)

Sélectionner et justifier les formats et outils pédagogiques adaptés à chaque public et contexte

Concevoir et mener une simulation de campagne de phishing interne respectant le cadre éthique et légal

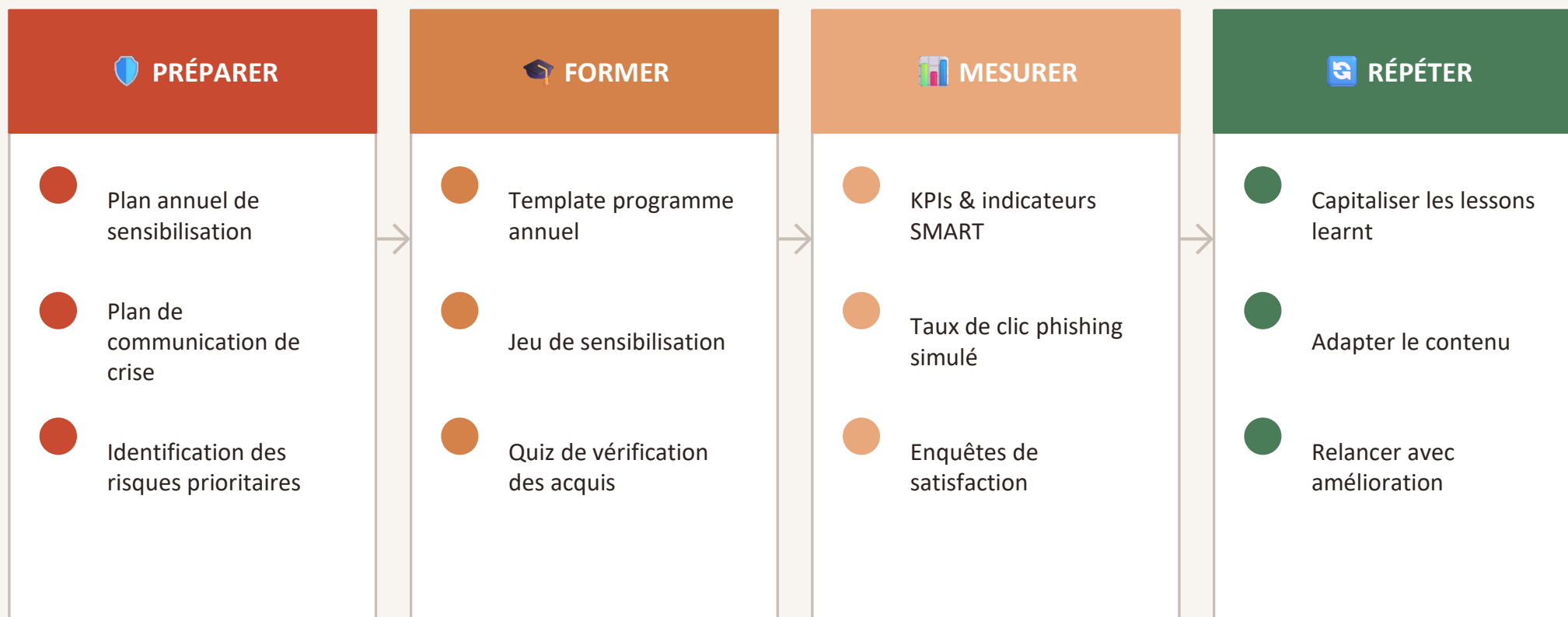
Intégrer les thématiques de protection des données : chiffrement, RGPD, stockage, archivage, plateformes d'échange

Configurer les mécanismes de gestion des identités : IAM, SSO, Active Directory (compétence C16)

Concevoir un plan de communication de crise cyber et appliquer la méthode ACE de l'ENISA

Le cycle ENISA — Prepare, Train, Measure, Repeat

Un programme de sensibilisation efficace est un cycle continu, pas un événement ponctuel



Template programme annuel — ENISA AR-in-a-Box

8 dimensions à formaliser pour chaque action de sensibilisation

QUI

Niveau de connaissance de la cible (Aware / Trained / Expert)

COMMENT

Méthode et outil pédagogique

POURQUOI

Résultat attendu (objectif SMART)

QUAND

Mois, date, durée de l'action

QUOI

Thème de sensibilisation (phishing, RGPD, hygiène, ransomware...)

MESURE

KPI, métriques et moyens de mesure

RÉSULTAT

Résultat obtenu et prochaine étape

COÛT

Budget, temps, ressources mobilisées

Formats et outils pédagogiques — Panorama

Jeu / Gamification

Public : Tous

Durée : 30-60 min Impact :
★★★★★

Simulation phishing

Public : Tous

Durée : Continu Impact : ★★★★★

Tabletop exercise

Public : COMEX, IT

Durée : 2-4h Impact : ★★★★★

E-learning / MOOC

Public : Tous

Durée : 1-4h Impact : ★★★

Présentation + quiz

Public : Tous

Durée : 1-2h Impact : ★★★

Affichage / Infographie

Public : Tous

Durée : Passif Impact : ★★

Conférence experte

Public : COMEX

Durée : 1-2h Impact : ★★★★★

Newsletter cyber

Public : Tous

Durée : Mensuel Impact : ★★

Démonstration hack

Public : IT, métiers

Durée : 1h Impact : ★★★★★

Simulation de phishing interne — Méthodologie

Une campagne de phishing simulé doit être couplée à une formation — jamais punitive

1	Cadrage éthique	Valider avec la direction et les RH. Définir les règles : anonymisation, pas de sanctions.
2	Conception du scénario	Choisir un prétexte crédible (RH, IT, direction). Créer l'email et la landing page de sensibilisation.
3	Envoi et collecte	Envoyer à un échantillon ou à tous. Mesurer : taux d'ouverture, taux de clic, signalements.
4	Sensibilisation immédiate	Afficher un message pédagogique à ceux qui ont cliqué. Expliquer les indices manqués.
5	Rapport & formation	Partager les résultats anonymisés. Organiser une formation ciblée pour les groupes à risque.

Exemple — Email de phishing simulé (MiniBiz)

Identifier les indices suspects — Exercice de détection

 Boîte de réception

De : portal@megacorp.test
À : hr@minibiz.com
Objet : Nouveau CV soumis pour examen

Cher(e) RH,

Un nouveau CV a été soumis via notre portail.
Merci de télécharger la pièce jointe pour examen.

 CV_SILVIO_S.docx

Indices suspects

-  Domaine expéditeur @megacorp.test (fictif)
-  Pièce jointe .docx avec macros
-  Aucune signature professionnelle
-  Email envoyé via 'portal' — inhabituel
-  Demande implicite d'ouvrir un fichier

Protection des données — RGPD & bonnes pratiques

La sensibilisation des utilisateurs est une obligation légale au titre du RGPD (Art. 39)



Chiffrement

- Chiffrer les emails sensibles (S/MIME)
- Disques et clés USB chiffrés
- HTTPS obligatoire pour les transferts
- VPN pour le travail à distance



Sauvegarde

- Règle 3-2-1 : 3 copies, 2 supports, 1 off-site
- Sauvegardes testées régulièrement
- Séparation backup / réseau principal
- Délai de rétention défini



Partage sécurisé

- Plateformes approuvées uniquement
- Pas de clés USB non chiffrées
- Droits d'accès limités au besoin
- Traçabilité des accès aux données



RGPD

- Notification violation 72h (Art. 33)
- Registre des traitements
- Minimisation des données
- Droits des personnes (accès, effacement)

Stockage, archivage et plateformes d'échange sécurisées (C17)

Compétence C17 — Formats, modalités de stockage, archivage et adéquation des plateformes d'échange



Stockage & archivage

- Données au repos : chiffrement AES-256 obligatoire (disques, BDD, archives)
- Données en transit : TLS 1.2+ minimum, HTTPS, VPN
- Formats d'archivage : formats ouverts pérennes (PDF/A, ODF, XML)
- Règle de rétention : définir les durées légales (RGPD, Code du travail)
- Séparation physique : archives froides isolées du réseau de production



Plateformes d'échange

- Évaluer les plateformes : SecNumCloud (ANSSI), HDS (santé), ISO 27001
- Cloud souverain vs. cloud étranger : enjeux RGPD (transferts hors UE)
- Shadow IT : interdire les outils non approuvés (WeTransfer, Dropbox perso)
- DLP (Data Loss Prevention) : prévenir les transferts non autorisés
- Traçabilité : journaux d'accès et d'échanges conservés 6 mois minimum



Cadre réglementaire

- RGPD Art. 32 : mesures techniques et organisationnelles appropriées
- RGPD Art. 44-49 : transferts de données hors UE — clauses contractuelles
- HDS (Santé) : hébergement certifié obligatoire pour données de santé
- NIS2 : exigences de sécurité sur la chaîne d'approvisionnement numérique
- ANSSI Guide : recommandations chiffrement et gestion des clés

Gestion de crise — PRA et bascule sur réseau secondaire (C12)

Compétence C12 — Processus de bascule adapté aux configurations sur les réseaux secondaires

PRA — Plan de Reprise d'Activité

RTO

Recovery Time Objective — Durée max d'indisponibilité tolérée (ex: 4h)

RPO

Recovery Point Objective — Perte de données max tolérée (ex: 1h)

Détection

Alertes automatiques + escalade vers cellule de crise

Isolation

Déconnexion immédiate des systèmes compromis du réseau

Bascule

Activation du réseau secondaire (VLAN de secours, DMZ dédiée)

Restauration

Réintégration depuis sauvegardes saines + tests de validation

Bascule réseau secondaire



Réseau primaire compromis

Isoler immédiatement — couper les accès inter-VLAN



Activation VLAN de secours

Réseau dédié pré-configuré pour la continuité critique



Authentification renforcée

MFA obligatoire sur le réseau de secours — pas d'exception



Périmètre restreint

Seules les applications critiques activées (messagerie, ERP)



Supervision active

SIEM en mode alerte maximale pendant la phase de bascule

Objectif sensibilisation : former les équipes IT ET les utilisateurs clés aux procédures de bascule AVANT l'incident

Sécurité de la messagerie — Failles et bonnes pratiques

La messagerie reste le vecteur #1 des intrusions — 90% des incidents en démarrent

Risques principaux

- Phishing et spear-phishing
- Pièces jointes malveillantes (macro, PDF piégé)
- Usurpation d'identité (spoofing)
- Interception (MITM sans chiffrement)
- Fuite de données par email non chiffré

Mesures de protection

- SPF, DKIM, DMARC configurés
- MFA sur tous les comptes email
- Filtrage anti-spam et sandboxing
- Formation des utilisateurs à la détection
- Chiffrement S/MIME ou PGP pour données sensibles

Gestion des identités — IAM, SSO et Active Directory

Compétence C16 — Chaînes d'authentification et architecture des services d'identité

IAM

Identity & Access Management

Gouverne qui peut accéder à quoi. Inclut provisioning, déprovisioning, droits d'accès par rôle (RBAC) et traçabilité des accès.

SSO

Single Sign-On

Authentification unique pour accéder à plusieurs systèmes. Réduit la fatigue des mots de passe. Repose sur fédération d'identité (SAML, OAuth, OIDC).

Active Directory

Forêts, domaines, approbations

Annuaire d'entreprise. Structure en forêts > domaines. Relations d'approbation inter-domaines. Principal vecteur d'attaque par élévation de privilèges.

Communication de crise cyber — Plan et exécution

Plan de communication de crise — 3 phases ENISA

Source : ENISA — Cyber Crisis Communication Guide SME Edition 2024

PLANIFIER

- Analyse des risques et criticité
- Définir les objectifs de communication
- Identifier les parties prenantes
- Constituer l'équipe de crise
- Formaliser les protocoles d'engagement

EXÉCUTER

- Activer le plan dès l'incident détecté
- Communiquer : tailored, action, empathy, ongoing
- Gérer les médias et réseaux sociaux
- Templates email interne / externe / réseaux
- Exercer le plan (tabletop, fonctionnel, full-scale)

ÉVALUER

- Monitorer les réactions et sentiments
- Recueillir les retours parties prenantes
- Post-incident review
- Mettre à jour le plan
- Capitaliser en culture d'entreprise

Messages de crise — Méthode ACE (ENISA)

3 principes pour communiquer avec crédibilité et garder la confiance des parties prenantes

A

Accuracy & Transparency

Information vérifiée, factuelle, sans spéculation. Être transparent même si les informations sont incomplètes. Ne jamais masquer ou minimiser l'incident.

- *Dire ce que vous savez ET ce que vous ne savez pas encore*
- *Éviter les promesses que vous ne pouvez pas tenir*
- *Corriger rapidement toute information erronée*

C

Customised & Clear

Adapter le message à chaque groupe cible. Utiliser un langage simple et direct. Canaux différents selon les publics.

- *Employés : détails opérationnels et protection*
- *Clients : impact et mesures prises pour eux*
- *Médias : faits, chronologie, responsabilité*

E

Empathy & Assurance

Exprimer une préoccupation sincère pour les parties affectées. Assurer engagement à résoudre et prévenir la récurrence.

- *'Nous comprenons l'inquiétude que cela suscite'*
- *Proposer des actions concrètes pour les victimes*
- *Montrer que vous apprenez de l'incident*

Templates de communication de crise — Exemples

Source : ENISA Cyber Crisis Communication Toolbox 2024

Email interne — Employés

Objet : Mise à jour — incident cyber en cours

Chers collègues,

Nous traversons actuellement un incident de cybersécurité qui affecte nos systèmes. Notre équipe IT travaille activement à la résolution.

Votre sécurité est notre priorité. Nous vous tiendrons informés régulièrement.

Cordialement, [Direction]

Post réseaux sociaux

Important : Nous faisons face à un incident cyber affectant nos opérations. Nous travaillons à restaurer les systèmes. La sécurité de nos clients est notre priorité. Mises à jour régulières à suivre. #MINIBIZ #Cybersécurité

Évaluer l'efficacité et bâtir une culture cyber durable

Objectifs

Définir et calculer des KPIs SMART pour mesurer l'efficacité d'un programme de sensibilisation

Construire un tableau de bord de pilotage avec les 4 catégories de KPIs ENISA AR-in-a-Box

Interpréter les résultats d'une campagne phishing simulée et formuler des recommandations actionnables

Distinguer les 4 niveaux de maturité cyber et identifier les leviers de progression vers la culture

Mesurer l'efficacité — KPIs SMART (ENISA)

Un KPI qui ne peut pas être mesuré ne peut pas être amélioré

S

Spécifique

Définir précisément ce qu'on mesure

M

Mesurable

Quantifiable par un indicateur concret

A

Atteignable

Réaliste compte tenu des ressources

R

Réaliste

Aligné sur les besoins de l'organisation

T

Temporel

Associé à une échéance définie

Exemples de KPIs — Source ENISA AR-in-a-Box 2024



90% des incidents signalés par employés en < 24h



50% des employés signalent un email de phishing simulé



90% des employés ont suivi au moins 1 formation/an



80% ont passé le quiz avec succès sur 12 mois

Catégories de KPIs — Tableau de bord ENISA

Changement de comportement	Portée de la sensibilisation	Perception publique	Durabilité
- Taux de signalement des incidents - Taux de clics sur phishing simulé - Taux d'activation du chiffrement - Infos sensibles partagées avec non-autorisés	% population formée sur 12 mois - Nombre d'adaptations de politique % quiz réussi sur 12 mois - Mesures de sécurité implémentées	- Taux de satisfaction (enquête) - Engagement sur les campagnes - Score NPS post-formation - Mentions positives médias	- Budget par personne / KPI atteint - Ressources nécessaires / objectifs - Maintien des comportements 6 mois+ - Réduction des incidents récurrents

De la sensibilisation ponctuelle à la culture d'entreprise

L'objectif final : que la sécurité devienne un réflexe naturel, pas une contrainte

Caractéristiques d'une culture cyber mature

Formation obligatoire, check-box, pas d'engagement réel

Conformité

1

Campagnes régulières, utilisateurs informés des risques

Sensibilisation

2

Changements mesurables, réflexes de sécurité adoptés

Comportement

3

La sécurité est une valeur partagée, portée par tous y compris le COMEX

Culture

4

Capitaliser — Retours d'expérience et leçons apprises

Chaque incident ou exercice est une opportunité d'améliorer le programme

Cas 1 — Attaque supply chain (Suède, 2023)

Communication transparente via communiqué de presse. Explication technique et impact client clairement détaillés.

Délai de détection trop long. Backup serveurs sur même réseau que l'attaque — à corriger.

Cas 2 — Télécommunications (Royaume-Uni, 2015)

CEO face aux médias rapidement. Soutien concret aux clients affectés. Communication proactive réputationnelle.

Violation des données n'aurait pas dû se produire. La rapidité de réponse a néanmoins limité l'impact.

Synthèse — Les 10 commandements de la sensibilisation

1

Partir des menaces réelles, pas des théories

3

Utiliser le storytelling et les scénarios concrets

5

Mesurer avec des KPIs SMART définis en amont

7

Impliquer le COMEX — l'exemple vient d'en haut

9

Préparer un plan de communication de crise avant l'incident

2

Adapter le message à chaque public (COMEX, IT, métiers)

4

Combiner plusieurs formats (jeu, simulation, quiz)

6

Répéter régulièrement — la sensibilisation n'est pas ponctuelle

8

Ne jamais punir — créer un environnement de confiance

10

Viser la culture, pas la conformité

Ressources — Pour aller plus loin

EU ENISA

- AR-in-a-Box — enisa.europa.eu/topics/cybersecurity-education
- ENISA Threat Landscape — rapport annuel menaces
- European Cybersecurity Month — cybersecuritymonth.eu
- SecureSME — enisa.europa.eu/securesme

FR ANSSI

- Guide d'hygiène informatique (42 règles)
- MOOC SecNum Académie — ssi.gouv.fr
- CERT-FR — alertes et bulletins de sécurité
- Référentiel PRIS pour prestataires



CNIL

- Guides RGPD pratiques — cnil.fr
- Formation DPO certifiée
- Outils d'auto-évaluation conformité
- Registre des traitements — modèles

MERCI

Module Sensibiliser les utilisateurs à la cybersécurité
Master 2 — Mastère Cybersécurité — NEXA

Questions & échanges

Ressources : enisa.europa.eu/topics/cybersecurity-education/awareness-raising-in-a-box

Source : ENISA — AR-in-a-Box SME Edition 2024 | © European Union Agency for Cybersecurity